XOR SECURE CLOUD

Kiến trúc tham chiếu và khung hồ sơ hệ thống thông tin cấp độ 4

XOR STACK CLOUD dựa trên OpenStack
DC tại IDC Cầu Giấy
DR tại IDC Nam Thăng Long

Bản mẫu 1.0 • Ngày lập 17/10/2026 • Phục vụ thiết kế và chuẩn bị đánh giá

Kết luận thiết kế

Xây dựng hai cụm cloud độc lập tại DC và DR, bảo vệ theo nhiều vùng mạng, kiểm soát tập trung tài khoản đặc quyền và khóa, giám sát 24/7, sao lưu độc lập và kiểm thử khôi phục. Phạm vi đánh giá bao phủ toàn bộ nền tảng XOR STACK CLOUD cùng các dịch vụ quản trị dùng chung.

Cấp độ 4 là mục tiêu thiết kế và đề xuất đánh giá. Tài liệu này chưa xác nhận hệ thống đã đáp ứng hoặc được phê duyệt cấp độ 4. Kết luận phải dựa trên phạm vi được chốt, căn cứ đề xuất cấp độ, cấu hình thực tế, bằng chứng vận hành và kết quả kiểm tra.

Đã được người dùng xác nhận	Còn cần xác minh
Nền tảng XOR STACK CLOUD do XOR CLOUD phát triển lại và đóng gói từ OpenStack.	Phiên bản upstream, bản dựng XOR, bản vá, SBOM, các thành phần thực sự cung cấp.
DC: Trung tâm Hạ tầng IDC Cầu Giấy. DR: Trung tâm Hạ tầng IDC Nam Thăng Long.	Rack, nguồn điện, tuyến truyền, mức độc lập sự cố; tài nguyên và dung lượng từng site.
Phạm vi: toàn bộ nền tảng cloud và quản trị chung.	Chủ quản pháp lý, đơn vị vận hành, quy mô tenant, loại dữ liệu, dịch vụ, SLA, RPO/RTO.

Quy ước: “Yêu cầu” dẫn TCVN/Nghị định; “đề xuất” là quyết định kỹ thuật của bản mẫu; “dự thảo” chỉ là tham chiếu thiết kế bổ sung. Mọi hiện trạng chưa có bằng chứng được ghi “Chưa đủ bằng chứng”.

1 Phạm vi và căn cứ lập hồ sơ

Ranh giới hệ thống

Bao gồm cơ sở hạ tầng tại cả hai IDC; máy chủ, hypervisor, SDN, lưu trữ; portal/API XOR; control plane và CSDL trạng thái; IAM/PAM/KMS/PKI; DNS/NTP; hệ thống giám sát, nhật ký, sao lưu, DR; pipeline đóng gói và phát hành nền tảng; máy trạm và kênh quản trị có thể tác động tới nền tảng. Hạ tầng thuê ngoài vẫn phải có bằng chứng và phân định trách nhiệm.

Ứng dụng nghiệp vụ và dữ liệu của khách hàng là phạm vi HTTT của từng chủ quản. Hồ sơ nền tảng phải chứng minh dịch vụ nền, khả năng cách ly và trách nhiệm XOR; khách hàng vẫn phải đánh giá ứng dụng, tài khoản, dữ liệu và cấu hình do mình quản lý. Nền tảng đạt cấp độ 4 không tự động làm mọi hệ thống khách hàng đạt cấp độ 4.

Căn cứ hiện hành được đối chiếu

Nghị định 331/2026/NĐ-CP có hiệu lực từ 19/8/2026. Điều 14 quy định tiêu chí cấp độ 4; Điều 18 quy định thẩm quyền; Điều 21 và 22 quy định hồ sơ và thuyết minh. Căn cứ Điều 14 cần được chứng minh bằng chức năng, phạm vi phục vụ, loại thông tin và tác động rủi ro, không chỉ bằng mong muốn thương mại hoặc số lượng thiết bị bảo mật. [S1, tr.9, 11–16, 30]

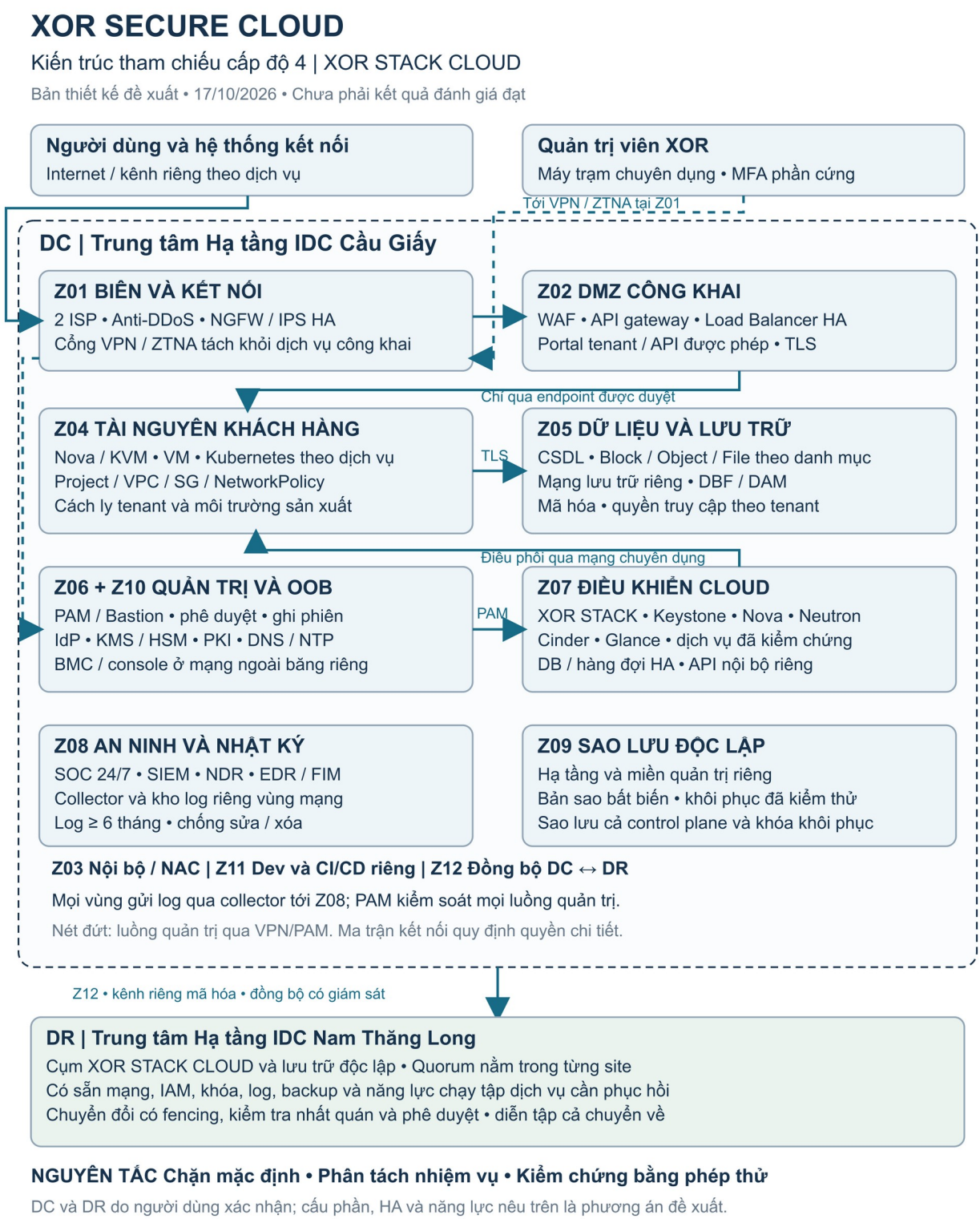
Trường hợp thông thường, Bộ Công an chủ trì thẩm định cấp độ 4; chủ quản phê duyệt hồ sơ. Hệ thống quân sự và hệ thống thông tin cơ yếu thuộc các trường hợp riêng tại Điều 18 khoản 3. Dự án đầu tư trước 1/7/2026 cần rà soát điều khoản chuyển tiếp tại Điều 39; chưa có dữ liệu để xác định XOR thuộc trường hợp này. [S1, tr.11–12, 30]

TCVN 14423:2026, Điều 6 và Phụ lục A.4 là cơ sở kỹ thuật của bản mẫu. Nghị định 85/2016 và Thông tư 12/2022 chỉ được đối chiếu theo phạm vi còn áp dụng/chuyển tiếp, không được mặc định là tuyến thủ tục duy nhất cho hồ sơ lập mới này.

Tham chiếu đám mây có điều kiện

Dự thảo TCVN Cloud chưa có số chính thức. Bản mẫu giả định mô hình phục vụ nhiều chủ quản MH3, cấp cao nhất phục vụ là 4 và không thuộc Danh mục HTTT quan trọng về an ninh quốc gia. Theo dự thảo, tuyến tham chiếu là Mức 4, phần mềm tối thiểu Hạng B, phân tách lô-gic hoặc cao hơn. Đây chưa phải kết quả đánh giá XOR STACK đạt Hạng B. Nếu giả định thay đổi phải xác định lại tuyến áp dụng. [S3, 4.1.14, 5.1, tr.16, 84–87; 5.3, tr.90–91]

2 Sơ đồ kiến trúc tổng thể



Hình 1. Kiến trúc đề xuất; số lượng cụm, cấu hình HA và phương thức tích hợp phải được xác nhận trong thiết kế chi tiết.

3 Phân vùng mạng và ranh giới tin cậy

Mỗi vùng có VLAN/VRF hoặc mạng ảo riêng, chính sách chặn mặc định, chủ sở hữu và danh sách kết nối được phê duyệt. CIDR dưới đây chỉ minh họa, phải kiểm tra xung đột với mạng hiện hữu và mạng khách hàng trước khi dùng. [S2, 6.12.2.1–6.12.2.6, tr.72–75]

Vùng	Chức năng và giới hạn	CIDR minh họa DC
Z01 Biên	Router/NGFW HA, chống DDoS, cổng kết nối ISP và cổng truy cập quản trị từ xa. Tách listener quản trị với dịch vụ người dùng.	Theo ISP và thiết kế biên
Z02 DMZ	WAF, reverse proxy, API gateway, LB. Chỉ công khai portal tenant và API có chủ đích. Admin endpoint và backend không công khai.	10.64.10.0/24
Z03 Nội bộ	Mạng người dùng nội bộ với NAC/kiểm tra thiết bị. Máy trạm quản trị chuyên dụng là nhóm riêng, không truy cập thẳng backend.	10.64.20.0/24
Z04 Tenant	VM và container theo project/tenant; phân đoạn app và môi trường. SG/ACL/NetworkPolicy theo luồng; chặn đi xuyên tenant.	CIDR riêng từng tenant
Z05 Dữ liệu	CSDL, block/object/file, tách storage client và storage replication. CSDL quản trị nền tảng nằm ở phân khu riêng trong Z07.	10.64.40.0/24 và dải storage riêng
Z06 Quản trị	PAM, bastion và dịch vụ quản trị; tách phân khu IAM, KMS/HSM, PKI, DNS/NTP bằng ACL và vai trò. Tài nguyên quản trị không kết nối Internet.	10.64.60.0/24

Nguồn cấp bản vá/ảnh đi qua vùng trung chuyển có kiểm tra, chữ ký và phê duyệt rồi nhập vào kho nội bộ. Không mở đường ra Internet trực tiếp cho tài nguyên quản trị để cập nhật. Kênh truy cập từ xa kết thúc tại cổng được kiểm soát, chuyển tiếp phiên qua PAM; không tạo quyền định tuyến rộng tới Z06/Z07.

Hệ thống cần kết nối Internet phải có ít nhất hai luồng Internet quốc tế từ nhà cung cấp trong nước có hạ tầng khác nhau. Kết nối vùng lõi với vùng ít tin cậy cần Datadiode, USG, BSG hoặc phương án kiểm soát rủi ro tương đương được thuyết minh; không mặc định một firewall bất kỳ là đủ. Chọn cơ chế một chiều hay hai chiều theo luồng nghiệp vụ đã xác định. [S2, 6.12.2.2, tr.73]

4 Các vùng bảo vệ nền tảng

Vùng	Chức năng và giới hạn	CIDR minh họa DC
Z07 Điều khiển	API nội bộ, controller, DB trạng thái và hàng đợi. Dịch vụ nền dùng tài khoản riêng, TLS/mTLS và allowlist. Tách luồng API, DB, queue, live migration.	10.64.70.0/24
Z08 An ninh	Collector, SIEM, NDR, quản lý EDR/FIM và kho log. Khác vùng sinh log; quyền quản trị kho log độc lập với vận hành cloud.	10.64.80.0/24
Z09 Sao lưu	Backup controller/repository trên hạ tầng độc lập với môi trường chạy dịch vụ. Tài khoản, khóa và quyền xóa tách biệt.	10.64.90.0/24
Z10 OOB	BMC/IPMI/Redfish, console, quản trị switch/nguồn. Switch/VRF riêng; không từ Internet hoặc tenant truy cập được.	10.64.100.0/24
Z11 Phát triển	Git, CI, build runner, registry và thử nghiệm. Tách dev/test/prod; triển khai production bằng tác nhân có quyền hẹp.	10.64.110.0/24
Z12 Liên site	Đồng bộ DC–DR trên kênh riêng, mã hóa; chỉ tài khoản và luồng sao chép được duyệt. Giám sát lag, băng thông và mất kết nối.	Dải riêng theo kết nối

Quy tắc liên vùng

• Z01 → Z02 → Z04 → Z05 là luồng nghiệp vụ chính. Z02 không được truy cập tùy ý DB, queue, KMS hoặc OOB.

• Z06 chỉ cấp phiên quản trị tới đích cụ thể, theo thời hạn và nhiệm vụ. Quản trị cloud và quản trị bảo mật/khóa tách vai trò; kiểm toán viên chỉ đọc.

• Z04 không có đường mạng trực tiếp vào mạng quản trị, storage backend hoặc control plane nội bộ. Metadata, console, volume attach, snapshot và live migration đều phải kiểm thử cách ly.

• Z08 nhận log qua collector và xuất cảnh báo qua cổng kiểm soát. Không dùng quyền cloud admin để xóa log hoặc bản sao lưu.

• Tại DR, dùng không gian mạng riêng, ví dụ 10.65.0.0/16; cùng mẫu chính sách, không kéo dài L2 mặc định giữa hai site.

5 Thiết kế XOR STACK CLOUD

Các tên thành phần dưới đây là ánh xạ đề xuất để khảo sát, không khẳng định mọi dịch vụ đã có trong bản dựng XOR. Mỗi dịch vụ phải được gắn phiên bản, cấu hình, chủ sở hữu và kiểm thử tương ứng. OpenStack Security Guide chỉ hỗ trợ tư duy kiến trúc; chính tài liệu cảnh báo nội dung từng được cập nhật theo các bản phát hành cũ. [S4]

Khối	Phương án thiết kế	Bằng chứng cần có
Control plane	Cụm controller quorum trong từng site; gợi ý 3 node. DB và hàng đợi có HA theo bản dựng hỗ trợ; không kéo quorum DC–DR. LB/API HA.	Sơ đồ node/rack, cấu hình cluster, thử mất node và khởi động lại.
Compute	Nova/KVM, cụm compute đủ N+1 theo tải; scheduler/host aggregate tách vùng lỗi. Nhóm cấp độ 4 có thể dùng pool riêng theo rủi ro.	Host mapping, capacity, placement, isolation và hardening.
Mạng	Neutron/SDN có router/gateway HA; chống giả mạo địa chỉ, SG chặn mặc định; không gộp mạng tenant với quản trị/underlay.	Driver thực tế, VLAN/VXLAN, bảng luật, route và kết quả thử.
Lưu trữ	Cinder/Glance và backend đã lựa chọn; Ceph nếu xác nhận sử dụng. Cụm độc lập mỗi site, phân bố dữ liệu theo miền lỗi.	Pool/CRUSH, replica hoặc EC, min_size, quyền tenant, khóa, thử lỗi.
Dịch vụ quản lý	DBaaS, Kubernetes, LB, object/file và GPU chỉ đưa vào hồ sơ khi có dịch vụ thực tế; nêu phiên bản, trách nhiệm XOR/khách hàng.	Danh mục dịch vụ, endpoint, SLA, cấu hình và kiểm thử chức năng.
Bản dựng XOR	SBOM, commit, image digest, chữ ký, provenance, bản vá, khác biệt với upstream và quy trình hỗ trợ vòng đời.	Hồ sơ phát hành, scan, review, kiểm thử và rollback.

Dịch vụ nền không được tạo vòng phụ thuộc khi phục hồi

Giữ tài liệu khôi phục, thông tin truy cập khẩn cấp và bản sao cấu hình ở nơi có thể tiếp cận khi cloud dừng hoàn toàn. Dự phòng DNS/NTP, IAM/PAM, KMS/HSM và kho image cần thiết cho khởi động lại. Thử khởi động nguội để phát hiện trường hợp phải có cloud mới khôi phục được cloud. [S3, 5.3.6–5.3.10, tr.92]

6 Định danh đặc quyền và bảo vệ dữ liệu

Tài khoản và quyền quản trị

Tích hợp IAM/IdP với portal và hệ thống quản trị; định danh cá nhân, MFA, RBAC, thu hồi theo nhân sự và rà soát quyền. Quyền hạ tầng, bảo mật/khóa và kiểm toán tách biệt. Dùng PAM để cấp quyền theo nhu cầu, giới hạn thời gian, ghi phiên và ràng buộc ticket. Tài khoản dịch vụ có chủ sở hữu, scope hẹp và vòng đời bí mật riêng. [S2, 6.6, tr.64–66]

Đề xuất MFA bằng thiết bị phần cứng chống sao chép cho mọi tài khoản đặc quyền vận hành; đây cũng là yêu cầu Mức 4 trong dự thảo. Không coi OTP phần mềm mặc nhiên đáp ứng yêu cầu phần cứng này. Cơ chế khẩn cấp phải có phê duyệt, giới hạn thời gian, cảnh báo và hậu kiểm. [S3, 5.5.2.3, 5.6, tr.95–98]

Khóa và mã hóa

KMS tích hợp HSM, phân quyền quản trị khóa khác quản trị hạ tầng. Tách khóa theo mục đích, tenant và môi trường; có luân chuyển, thu hồi, backup/restore khóa và chứng thư. Với dự thảo Mức 4, khóa chủ lưu trong HSM và mã hóa dữ liệu lưu trữ bật mặc định ở mức nền tảng. Sự có mặt của Barbican/KMS không tự chứng minh các điều kiện này. [S3, 5.4.5.3–5.4.8, tr.93–95]

Phân loại dữ liệu xác thực, trạng thái nền tảng, log, bản sao lưu, dữ liệu khách hàng và dữ liệu nhạy cảm. Đối với dữ liệu quan trọng: mã hóa lưu trữ; khi truyền, thiết kế hai lớp bảo vệ, ví dụ TLS ứng dụng trong đường hầm IPsec, hoặc phương án kiểm soát rủi ro tương đương được thuyết minh và kiểm chứng. Không dùng việc kết thúc TLS rồi tái mã hóa ở LB để gọi là hai lớp mã hóa đồng thời. [S2, 6.4.2.4, tr.62]

Giới hạn bảo vệ phải công bố

Mã hóa đĩa không tự ngăn quản trị viên hypervisor đọc bộ nhớ hoặc dữ liệu đã giải mã. Công bố rõ ai có thể giải mã, khả năng truy cập snapshot/volume/console, cơ chế chấp thuận của khách hàng và tùy chọn khóa do khách hàng kiểm soát. Mọi sao chép/xuất dữ liệu phải được ghi vết. [S3, 5.6.10–5.6.13, tr.97–98]

Triển khai DLP theo loại dữ liệu và kênh thoát; giám sát truy cập CSDL bằng DBF/DAM hoặc phương án tương đương; kiểm soát object ACL, URL ký có hạn và mã hóa backup. Quy trình trao đổi dữ liệu quan trọng phải xử lý yêu cầu chữ ký số, không đồng nhất chữ ký số nghiệp vụ với TLS. [S2, 6.4.2.8–6.4.2.10, tr.63; 6.12.2.2, tr.73]

7 Sẵn sàng cao và dự phòng thảm họa

DC Cầu Giấy chạy sản xuất; DR Nam Thăng Long duy trì cụm cloud độc lập và tài nguyên dự phòng. Đây là phương án đề xuất, chưa xác nhận năng lực hai IDC. HA trong site xử lý lỗi node/thiết bị; DR xử lý mất site. Sao chép dữ liệu không thay thế bản sao lưu có lịch sử sạch.

Đối tượng	Thiết kế đề xuất	Mục tiêu ban đầu cần phê duyệt
Control plane	HA nội site; backup DB/cấu hình nhất quán; khôi phục vào cụm DR theo runbook có đối soát ID và tài nguyên.	RPO ≤ 15 phút; RTO ≤ 4 giờ
Tenant quan trọng	Replication ứng dụng/DB hoặc cơ chế bảo vệ volume được kiểm chứng; khôi phục mạng, DNS, khóa và dependency.	RPO ≤ 15 phút; RTO ≤ 4 giờ theo hợp đồng
Kho image và cấu hình	Bản sao có chữ ký/digest ở DR; artifact và cấu hình khai báo được quản lý phiên bản.	RPO ≤ 24 giờ; RTO ≤ 4 giờ
Log và bằng chứng	Đệm tại collector, chuyển tới kho độc lập; bản sao ở DR, kiểm tra toàn vẹn và mất chuỗi.	Đề xuất lag ≤ 5 phút; lưu tối thiểu 6 tháng
Backup	Quy tắc 3-2-1 hoặc tương đương; bản sao trên hạ tầng độc lập; bất biến theo chính sách đã chốt.	Đề xuất giữ bất biến 30 ngày; thử phục hồi theo chu kỳ

Các số RPO/RTO và 30 ngày là mục tiêu thiết kế ban đầu, không phải ngưỡng bắt buộc chung của TCVN và chưa là cam kết dịch vụ. Chốt sau BIA, đo tốc độ thay đổi dữ liệu, băng thông, dung lượng và thời gian khôi phục end-to-end. RTO tính từ lúc gián đoạn tới lúc dịch vụ dùng được, bao gồm phát hiện, quyết định, phục hồi và kiểm tra.

Trình tự chuyển đổi DR

Phát hiện và xác minh sự cố → chỉ huy phê duyệt kích hoạt → cô lập/fencing site cũ để tránh hai nơi cùng ghi → khôi phục DNS/IAM/KMS và control plane → kiểm tra điểm dữ liệu nhất quán → khôi phục dịch vụ ưu tiên → chuyển tuyến/DNS → xác nhận người dùng → theo dõi → đồng bộ và chuyển về có kế hoạch.

Không mặc định kéo dài Ceph, DB hoặc quorum OpenStack qua hai site. Tài liệu Ceph nêu mô hình stretch hai vùng cần vùng thứ ba cho tiebreaker; phương án hiện tại chọn cụm độc lập vì chưa có thiết kế quorum và miền thứ ba. [S5]

Hai IDC cùng khu vực Hà Nội có thể chịu rủi ro tương quan. Cần xác minh điện, nhà mạng và tuyến cáp độc lập; cân nhắc bản sao offline/offsite ngoài cùng miền sự cố. Không khẳng định đã có site thứ ba. [S2, 6.11, tr.71–72; S3, 5.10, tr.105–106]

8 Giám sát nhật ký và vận hành an ninh

SOC tổ chức giám sát 24/7 với nhân sự trực, cơ chế bàn giao ca, đầu mối ứng cứu và thời gian xử lý theo mức nghiêm trọng. SIEM chỉ là một thành phần; phải chứng minh dữ liệu đầy đủ, quy tắc phát hiện hoạt động và cảnh báo được xử lý. [S2, 6.13.2.1, tr.75]

Nguồn	Sự kiện tối thiểu cần đưa vào phạm vi thiết kế
Biên và mạng	WAF, NGFW/IPS, chống DDoS, DNS, VPN/ZTNA, flow log; kết nối bị chặn, đường quản trị và egress.
Định danh và quản trị	Đăng nhập, MFA, cấp/thu hồi role, thay đổi policy, PAM session, break-glass, thay đổi khóa/chứng thư.
XOR/OpenStack	Thao tác API; tenant/project; image, snapshot, volume attach/export; console; thay đổi SG, route và metadata; thao tác của nhân viên XOR.
Hạ tầng và dữ liệu	Hypervisor, OS, EDR/FIM, DB/DAM, storage, backup, HSM/KMS; lỗi replica, truy cập dữ liệu, xóa hoặc đổi retention.
Chuỗi phát hành	Git/CI, build, scan, phê duyệt, chữ ký artifact, deploy, rollback; thay đổi cấu hình production.

Bảo vệ và lưu giữ

Thu thập nhật ký truy cập, tiến trình, ứng dụng, truy cập dữ liệu và cảnh báo trên toàn bộ tài sản trong phạm vi. Đồng bộ thời gian; có tenant ID, actor, nguồn/đích, thao tác, thời điểm và kết quả. Giảm dữ liệu bí mật trong log. Kho log đặt riêng vùng mạng, hạn chế sửa/xóa và ghi lại truy cập vào chính kho log. [S2, 6.8.2.1–6.8.2.3, tr.68–69]

Lưu nhật ký tối thiểu 6 tháng theo TCVN; đề xuất lớp tìm kiếm nhanh 90 ngày và lớp lưu trữ để tổng thời gian ít nhất 6 tháng, kéo dài theo nghĩa vụ dữ liệu/hợp đồng. Giám sát đầy đĩa, chậm nhận, mất nguồn và lệch giờ. Dự thảo còn yêu cầu chuyển log tới hệ thống độc lập với nền tảng và xác nhận chuyển thành công. [S3, 5.9.3, tr.103]

Bộ tình huống phát hiện ban đầu

Tạo quyền admin bất thường; thay đổi hoặc tắt MFA; truy cập chéo tenant; sao chép volume/memory; vô hiệu EDR/log; xóa hàng loạt; thay đổi retention; thất bại backup; lag DR; KMS lỗi; brute force; egress bất thường. Mỗi tình huống có dữ liệu nguồn, logic, ngưỡng, người xử lý và phép thử tạo cảnh báo.

Cơ chế kết nối giám sát/báo cáo tới cơ quan có thẩm quyền được thiết kế qua cổng riêng theo yêu cầu áp dụng thực tế; phải có phương án bảo vệ dữ liệu và phân tách tenant. Không tự gửi dữ liệu khách hàng hoặc mặc định mở kết nối ra ngoài trong bản mẫu.

9 Mẫu tài nguyên Kubernetes và chỉnh sửa sơ đồ đầu vào

Kubernetes là một mẫu tài nguyên được nền tảng cung cấp, không đại diện cho toàn bộ phạm vi cloud. Khi có dịch vụ này, lựa chọn cụm riêng cho khách hàng cấp độ 4 là đề xuất giảm rủi ro; không coi namespace là ranh giới duy nhất giữa các chủ quản không tin cậy.

Thành phần	Thiết kế cho mẫu Kubernetes
Ingress và ứng dụng	WAF → LB → ingress → workload. TLS trên các chặng; mTLS và lớp bảo vệ bổ sung cho dữ liệu quan trọng. Hạn chế egress theo đích.
Điều khiển cụm	API private qua mạng quản trị/PAM; RBAC tối thiểu; audit log; etcd mã hóa và sao lưu. Control plane có quorum nội site.
Workload	NetworkPolicy mặc định chặn, CNI có thực thi chính sách; Pod Security phù hợp; hạn chế privileged/hostPath/hostNetwork; tách node pool và quota.
Chuỗi cung ứng	Registry riêng; image theo digest, scan và xác minh chữ ký; không nhúng secret trong Git/image; admission policy kiểm tra trước chạy.
DR	Cụm DR độc lập; manifest và secret phục hồi có kiểm soát, dữ liệu PV nhất quán; thử khôi phục toàn ứng dụng. Không chỉ sao lưu manifest.

Thiết kế kỹ thuật Kubernetes cần đối chiếu tài liệu bảo mật của phiên bản đang vận hành; checklist chính thức hỗ trợ rà soát nhưng không thay thế ma trận TCVN. [S6]

Những thay đổi cần đưa vào hình hiện tại

• Bổ sung control plane OpenStack, hypervisor, backend storage, OOB, CI/CD phát hành XOR, kho log và backup độc lập; thể hiện cả DC và DR.

• Thay đường HTTP từ LB tới workload bằng kết nối được bảo vệ. Phân biệt kết thúc TLS, tái mã hóa và hai lớp mã hóa cho dữ liệu quan trọng.

• Đặt IDS/NDR ở điểm quan sát qua TAP/SPAN; chỉ thể hiện IPS inline khi thực sự triển khai. DNS và Elastic IP không phải thiết bị bảo mật nối tuần tự.

• Tách WAF cho portal/API nền tảng với WAF cho ứng dụng khách hàng. Không dùng một VPC để biểu diễn toàn bộ ranh giới nhà cung cấp cloud.

• Thể hiện rõ luồng log, backup, quản trị và đồng bộ DR; bổ sung DBF/DAM, DLP, EDR, NAC hoặc phương án tương đương theo phạm vi áp dụng.

• Giữ tên sản phẩm như RDS, CBR, EVS ở dạng dịch vụ minh họa nếu chưa phải danh mục XOR đã xác nhận; ánh xạ sang chức năng và bằng chứng thực tế.

10 Ma trận yêu cầu TCVN 14423 1

Ma trận thiết kế theo nhóm Điều 6. Tất cả các dòng có hiện trạng “Chưa đủ bằng chứng”; khoảng trống chung là chưa có bộ cấu hình và kết quả kiểm thử được xác thực. Hành động: triển khai/đối chiếu phương án, thu thập bằng chứng, kiểm tra rồi kết luận từng tiểu mục. Không dùng bảng nhóm này để tuyên bố đã hoàn tất checklist toàn bộ điều khoản.

Mã và điều khoản	Phương án đáp ứng đề xuất	Đầu mối và bằng chứng
C01 Rủi ro và BIA [S2] 6.1, tr.58–59	Lập rủi ro theo tài sản, tenant, nhà cung cấp; đánh giá tác động và chấp nhận rủi ro tồn dư.	GRC/chủ quản; sổ rủi ro, BIA, phê duyệt và đánh giá lại.
C02 Tài sản phần cứng [S2] 6.2, tr.59–60	CMDB cho host, switch, thiết bị bảo mật, BMC, máy trạm; phát hiện tài sản lạ, kiểm kê vòng đời.	Hạ tầng; CMDB, scan, DHCP/IPAM, biên bản tiêu hủy.
C03 Tài sản phần mềm [S2] 6.3, tr.60–61	Kiểm kê bản dựng XOR, upstream, container, agent, firmware; allowlist, EOL và ngoại lệ.	Platform; SBOM, catalog, support, phát hành và bản vá.
C04 Dữ liệu và mật mã [S2] 6.4, tr.61–63	Phân loại, ACL, luồng dữ liệu, mã hóa, toàn vẹn, DLP, truy cập và chữ ký số khi trao đổi dữ liệu quan trọng.	Data owner/bảo mật; DFD, phân loại, KMS, DLP và thử bảo vệ dữ liệu.
C05 Cấu hình an toàn [S2] 6.5, tr.63–64	Baseline theo từng loại node, dịch vụ, thiết bị và endpoint; vô hiệu dịch vụ thừa, khóa phiên, kiểm soát thiết bị di động.	Platform/IT; baseline, báo cáo drift và cấu hình thực tế.
C06 Tài khoản và đặc quyền [S2] 6.6, tr.64–66	IAM, MFA, PAM, phân tách nhiệm vụ, tài khoản cá nhân, quy trình cấp/đổi/thu hồi.	IAM/HR; ma trận quyền, ticket, phiên PAM và biên bản rà soát.

11 Ma trận yêu cầu TCVN 14423 2

Ma trận thiết kế theo nhóm Điều 6. Tất cả các dòng có hiện trạng “Chưa đủ bằng chứng”; khoảng trống chung là chưa có bộ cấu hình và kết quả kiểm thử được xác thực. Hành động: triển khai/đối chiếu phương án, thu thập bằng chứng, kiểm tra rồi kết luận từng tiểu mục. Không dùng bảng nhóm này để tuyên bố đã hoàn tất checklist toàn bộ điều khoản.

Mã và điều khoản	Phương án đáp ứng đề xuất	Đầu mối và bằng chứng
C07 Lỗ hổng và bản vá [S2] 6.7, tr.67	Scan toàn hệ thống ≥ 6 tháng/lần; tài sản quan trọng ≥ quý/lần; xử lý theo rủi ro, kiểm thử và rollback bản vá.	SecOps/Platform; scan, ticket, đánh giá tác động và retest.
C08 Nhật ký [S2] 6.8, tr.68–69	Thu thập đủ loại log, đồng bộ giờ; SIEM; lưu ≥ 6 tháng; bảo vệ sửa/xóa, riêng vùng mạng.	SOC; mẫu log, pipeline, retention, kiểm tra mất log và toàn vẹn.
C09 Trình duyệt và email [S2] 6.9, tr.69–70	Bảo vệ máy trạm vận hành, lọc DNS/URL, quản lý extension, DMARC và tệp đính kèm theo phạm vi.	IT/SOC; policy, cấu hình và thử chặn. Không tự loại khỏi phạm vi vì cloud không bán email.
C10 Chống mã độc [S2] 6.10, tr.70–71	EDR hoặc tương đương có phát hiện hành vi, bảo vệ thời gian thực, quản trị tập trung, kết nối SIEM.	SOC; độ phủ agent, chính sách và thử cảnh báo/cách ly.
C11 Sao lưu và khôi phục [S2] 6.11, tr.71–72	Sao lưu tự động, 3-2-1 hoặc tương đương; độc lập môi trường vận hành, mã hóa dữ liệu nhạy cảm; thử restore ≥ 6 tháng/lần.	Backup; job, hạ tầng repository, ACL và biên bản restore.
C12 Hạ tầng mạng [S2] 6.12, tr.72–75	Phân vùng, microsegmentation, FW/IPS, WAF/DDoS/DBF/NAC hoặc tương đương; mạng quản trị tách biệt; quản trị từ xa qua cổng kiểm soát.	Network; HLD/LLD, rule, route, thử cho phép và từ chối.

12 Ma trận yêu cầu TCVN 14423 3

Ma trận thiết kế theo nhóm Điều 6. Tất cả các dòng có hiện trạng “Chưa đủ bằng chứng”; khoảng trống chung là chưa có bộ cấu hình và kết quả kiểm thử được xác thực. Hành động: triển khai/đối chiếu phương án, thu thập bằng chứng, kiểm tra rồi kết luận từng tiểu mục. Không dùng bảng nhóm này để tuyên bố đã hoàn tất checklist toàn bộ điều khoản.

Mã và điều khoản	Phương án đáp ứng đề xuất	Đầu mối và bằng chứng
C13 Giám sát và phòng thủ [S2] 6.13, tr.75–76	Giám sát 24/7; tập trung cảnh báo; flow log; tách cổng quản trị; điều chỉnh ngưỡng ≥ quý/lần.	SOC; lịch trực, alert, ticket, rule và phép thử use case.
C14 Nhân sự [S2] 6.14, tr.76–77	Bộ phận vận hành, quản trị, bảo vệ an ninh có cơ chế độc lập chuyên môn; đào tạo, bảo mật và offboarding.	Lãnh đạo/HR; quyết định phân công, đào tạo, NDA, thu hồi quyền.
C15 Nhà cung cấp [S2] 6.15, tr.77	Quản lý IDC, ISP, phần mềm, SOC; ranh giới trách nhiệm, yêu cầu bảo mật, theo dõi và kết thúc hợp đồng.	Mua sắm/GRC; danh mục, hợp đồng, SLA và bằng chứng của nhà cung cấp.
C16 Phát triển an toàn [S2] 6.16, tr.78–79	SSDLC cho phần XOR sửa đổi; tách dev/test/prod; quản lý thư viện; kiểm tra mã nguồn, pentest và xử lý trước vận hành.	DevSecOps; review, SBOM, scan, test, phê duyệt release và rollback.
C17 Ứng phó sự cố [S2] 6.17, tr.79–80	Chỉ huy chính/dự phòng, quy trình liên lạc chính/phụ, phân loại, bảo toàn chứng cứ, hậu kiểm; diễn tập ≥ năm/lần.	CSIRT; kế hoạch, đầu mối, playbook, biên bản và bài học.
C18 Kiểm tra an ninh [S2] 6.18, tr.80–81	Pentest từ ngoài và từ trong tối thiểu năm/lần; phạm vi được phê duyệt, khắc phục và kiểm tra lại hiệu lực kiểm soát.	Đánh giá độc lập; ROE, báo cáo, retest và xác nhận đóng lỗi.

13 Vật lý và phần bổ sung đám mây

Vật lý theo Phụ lục A.4, không sao chép nguyên yêu cầu của cấp độ 5. Tại từng IDC cần chứng minh vị trí phòng máy, kiểm soát vào ra, camera giám sát 24/7 và lưu ≥ 6 tháng, rack bảo vệ, chống trộm, chống sét, chữa cháy, chống nước/tĩnh điện, điều hòa riêng, cảnh báo độ ẩm; hai nguồn từ hai trạm điện khác nhau và UPS; bảo vệ điện từ theo phạm vi. [S2, A.4.1–A.4.10, tr.109–111]

Bằng chứng: hồ sơ xây dựng/vận hành IDC, sơ đồ điện, kiểm định và bảo trì, kiểm soát khách/nhà thầu, ảnh hiện trường, dữ liệu camera, biên bản thử chuyển nguồn. Hợp đồng thuê IDC hoặc chứng nhận chung không đủ để tự kết luận mọi điều khoản đã đáp ứng.

Tham chiếu dự thảo [S3]	Hạng B và Mức 4 giả định MH3	Cách kiểm chứng
5.1; tr.84–87	Công bố phạm vi, hạng phần mềm, mức nền tảng, giới hạn và trách nhiệm chung.	Đối chiếu bản dựng, cấu hình và tài liệu đánh giá; không suy ra từ tên OpenStack.
5.3; tr.90–93	Cách ly tenant; không điểm lỗi đơn; khởi động nguội; ranh giới miền lỗi.	Thử tenant A → B, mất node, cô lập control plane và cold start.
5.4–5.5; tr.93–96	HSM cho khóa chủ, mã hóa mặc định; MFA phần cứng cho đặc quyền.	Đối chiếu nơi giữ khóa, thử MFA, quyền và luân chuyển.
5.6; tr.96–99	Tách ba vai trò, kiểm soát lạm quyền, phê duyệt nhiều bên, quyền khách hàng và giới hạn giải mã.	Thử quản trị viên đối kháng; kiểm tra bypass API, storage và hypervisor.
5.9; tr.103–105	Log ngoài nền tảng, cảnh báo đặc thù cloud, phân tách log theo chủ quản.	Phát sự kiện, kiểm tra đích nhận, mất kênh và truy vấn chéo tenant.
5.10; tr.105–106	Backup bất biến control plane và tenant; RPO/RTO công bố theo số đo.	Thử xóa bởi cloud admin, restore và mất site.
Điều 4; PL D/L	Đánh giá phần mềm và triển khai là hai phạm vi khác nhau; rà soát toàn bộ khoản bắt buộc áp dụng.	Lập checklist chi tiết theo hạng/mức/MH và xử lý tham chiếu chưa nhất quán của bản dự thảo.

Hiện trạng các mục trên: Chưa đủ bằng chứng. Bảng chỉ định hướng nâng mức bảo vệ; không thay thế đánh giá sự phù hợp Điều 4, Điều 5 hoặc phê duyệt cấp độ pháp lý.

14 Danh mục bộ hồ sơ cần hoàn thiện

Điều 21 Nghị định 331 quy định năm thành phần hồ sơ; Điều 22 yêu cầu báo cáo rủi ro chi tiết đối với cấp độ 4/5. Sơ đồ trong tài liệu là thiết kế tham chiếu, phải cập nhật thành thiết kế thực tế hoặc tài liệu tương đương phù hợp tình trạng dự án. [S1, tr.14–16]

Mã hồ sơ	Nội dung cần bàn giao	Trạng thái bản mẫu
HS01 Tổng quan	Chủ quản, đơn vị vận hành, chức năng, phạm vi, đối tượng phục vụ, quy mô và danh mục dịch vụ.	Đã có phạm vi và hai site; còn thông tin pháp lý/quy mô.
HS02 Thiết kế	HLD, LLD, mô hình vật lý/lô-gic, rack/node, VLAN/VRF/IP, kết nối, phần mềm và luồng dữ liệu.	Có HLD, vùng và luồng mẫu; LLD/as-built cần khảo sát.
HS03 Đề xuất cấp độ	Đối chiếu Điều 14, loại dữ liệu, phạm vi tác động, BIA, liên hệ HTTT khác và báo cáo rủi ro chi tiết.	Mục tiêu 4; chưa đủ căn cứ thực tế để kết luận.
HS04 Phương án bảo vệ	Thuyết minh từng yêu cầu quản lý/kỹ thuật Điều 6 và A.4; tổ chức, công cụ, vận hành, kiểm tra và ngoại lệ.	Có phương án và ma trận nhóm; cần checklist từng tiểu mục và bằng chứng.
HS05 Ý kiến chuyên môn	Ý kiến của đơn vị chuyên trách an ninh mạng với hồ sơ cấp độ 4.	Để đơn vị có trách nhiệm lập và ký.
HS06 Quản trị vận hành	Quy chế ANM, quy trình IAM/PAM, thay đổi, vá lỗi, log, backup, ứng cứu, nhà cung cấp, dữ liệu và nhân sự.	Danh mục và khung trách nhiệm; chưa phải quy trình ban hành.
HS07 Đánh giá	Kế hoạch kiểm tra, bằng chứng, pentest, DR, báo cáo khoảng trống, khắc phục và retest.	Kịch bản mẫu; chưa thực hiện kiểm thử hệ thống.
HS08 Thẩm định phê duyệt	Công văn, ý kiến thẩm định, tờ trình, quyết định và phụ lục phạm vi; phiên bản đóng hồ sơ.	Chưa có; chỉ lập sau khi đầy đủ dữ liệu và đúng thẩm quyền.

Biểu mẫu hành chính của Nghị định: Mẫu 03 xin ý kiến chuyên môn; Mẫu 02 đề nghị thẩm định; Mẫu 04 ý kiến thẩm định; Mẫu 05 tờ trình phê duyệt; Mẫu 06 quyết định phê duyệt cấp độ. Phải lấy đúng biểu mẫu và chủ thể ký; không tạo sẵn kết luận “đạt”. [S1, phụ lục, tr.32–40]

15 Khung thuyết minh và biểu ghi bằng chứng

Thông tin cần điền để hoàn thiện HS01 và HS03

Trường	Nội dung bản mẫu
Tên hệ thống	XOR SECURE CLOUD trên nền tảng XOR STACK CLOUD
Chủ quản pháp lý	[Tên pháp nhân, căn cứ chức năng, đại diện, địa chỉ, liên hệ]
Đơn vị vận hành và chuyên trách	[Tên, chức năng, người phụ trách và cơ chế độc lập]
Phạm vi địa lý	DC: IDC Cầu Giấy; DR: IDC Nam Thăng Long; [địa chỉ/rack/khu vực thuê thực tế]
Quy mô và đối tượng	[Tenant/chủ quản được phục vụ; VM/vCPU/RAM/storage; số người dùng; kết nối; tăng trưởng]
Thông tin được xử lý	[Phân loại dữ liệu nền tảng và khách hàng; dữ liệu cá nhân/quan trọng/bí mật nhà nước nếu có]
Căn cứ đề xuất cấp độ 4	[Khoản cụ thể Điều 14; bằng chứng về chức năng, phạm vi, hậu quả gián đoạn và yêu cầu 24/7 khi áp dụng]
Trường hợp đặc biệt	[Có/không thuộc Danh mục quan trọng về ANQG; dữ liệu bí mật nhà nước; quy định ngành; căn cứ kết luận]

Biểu ghi kiểm tra một yêu cầu

Mã yêu cầu: [Cxx/tiểu mục] • Điều/khoản và trang: […] • Phạm vi tài sản: […] • Chủ sở hữu: […] • Biện pháp đang áp dụng: […] • Bằng chứng E-ID: […] • Cách kiểm tra: […] • Ngày và người kiểm tra: […] • Kết quả: Đạt / Chưa đạt / Chưa đủ bằng chứng / Không áp dụng có căn cứ • Khoảng trống: […] • Hành động, người phụ trách, hạn: […] • Retest: […] • Người xác nhận: […].

Cách quản lý bằng chứng

Mỗi E-ID chứa mô tả, nguồn, phạm vi, thời điểm, phiên bản, hash và người thu thập. Tách bản gốc với bản đã che dữ liệu nhạy cảm; chỉ cấp quyền người cần xem. Với log và phiên PAM, lưu truy vết xuất dữ liệu. Tất cả trạng thái ban đầu của bộ hồ sơ này là “Chưa đủ bằng chứng”, không đánh dấu đạt chỉ bằng screenshot màn hình sản phẩm.

16 Ma trận kết nối mẫu

Các cổng dưới đây là gợi ý thiết kế, chưa là cấu hình để áp trực tiếp. LLD phải tách theo phiên bản, nguồn/đích/IP cụ thể, người sở hữu, thời hạn và ticket. Mọi luồng khác bị chặn; phản hồi phiên chỉ theo cơ chế stateful đã duyệt.

Nguồn → đích	Dịch vụ và kiểm soát	Bằng chứng kiểm tra
Internet → Z02	TCP 443 qua Z01/WAF; chỉ FQDN/endpoint công khai.	Không bypass WAF tới origin.
Z02 → Z04	443 hoặc cổng TLS ứng dụng đã chốt; allowlist LB/ingress.	Chặn trực tiếp vào pod/node ngoài luồng.
Z04 → Z05 DB	Cổng DB xác định, ví dụ 5432/3306; TLS + quyền DB; lớp bảo vệ thứ hai khi cần.	Chỉ app được phép; thử user sai/tenant khác.
Z04 → Object/File	Endpoint riêng, xác thực và quyền theo tenant; TLS hoặc giao thức có bảo vệ tương ứng.	Không public bucket/share ngoài chính sách.
PAW → VPN/ZTNA	Cổng theo giải pháp ở Z01; chứng thư thiết bị, MFA, trạng thái EDR.	Máy lạ và MFA sai bị từ chối.
Gateway → PAM Z06	Proxy/luồng đích hẹp; xác thực bổ sung; không cấp route toàn mạng.	Không truy cập đích khi bỏ qua PAM.
PAM → Z07/Z10	SSH/HTTPS/console theo allowlist đích và nhiệm vụ; ghi phiên.	Quyền hết hạn, log đầy đủ và chặn lệnh/đích ngoài phạm vi.
Dịch vụ Z07 ↔ backend	API/DB/queue theo bản dựng; TLS/mTLS, tài khoản dịch vụ riêng.	Không có any-to-any hoặc credential dùng chung.
Compute → storage	Chỉ client/backend cần thiết trên mạng storage; xác thực và mã hóa đã chọn.	Tenant không tới trực tiếp storage backend.
Các vùng → Z08	Syslog TLS 6514 hoặc agent HTTPS theo giải pháp; xác thực; đệm.	Nhận đủ log, cảnh báo mất nguồn.
Backup → tài sản/Z09	Danh sách cổng backup cụ thể, tài khoản quyền hẹp; repository độc lập.	Cloud admin không tự xóa bản sao bất biến.
Z12 DC ↔ DR	Replication được duyệt trên kênh riêng có mã hóa; chỉ peer cụ thể.	Đo lag, mất kênh, failover và consistency.
Z11 → production	Tác nhân deploy ở vùng quản lý với danh tính ngắn hạn; artifact ký.	Runner không có quyền admin toàn cloud.
Các vùng → DNS/NTP	Chỉ resolver/time server đã định danh; không truy vấn tùy ý ra Internet.	Chặn nguồn lạ; cảnh báo lệch giờ.

17 Kế hoạch kiểm thử nghiệm thu

Chỉ thực hiện sau khi phạm vi và cửa sổ kiểm thử được phê duyệt. Bản này thiết kế phép thử, chưa chạy pentest hoặc tác động lên hệ thống thật. Mỗi ca lưu điều kiện đầu vào, bước thực hiện, log, kết quả, người chứng kiến và retest.

Ca	Thử nghiệm	Tiêu chí chấp nhận đề xuất
T01	Phân vùng và công khai dịch vụ	Không có đường ngoài ma trận; origin không bypass WAF; admin API/DB/OOB không lộ ra Internet.
T02	Cách ly tenant	Tenant A không đọc/ghi/quản trị tài nguyên B qua API, mạng, metadata, volume, snapshot, object hoặc console.
T03	Đặc quyền và PAM	MFA/phê duyệt bắt buộc; quyền hết hạn; phiên truy vết được; thử đường bypass bị chặn hoặc phát hiện theo thiết kế.
T04	Khóa và dữ liệu	Kiểm tra mã hóa, quyền giải mã, thu hồi/luân chuyển và restore khóa; cloud admin không tự cấp quyền khóa.
T05	Log và phát hiện	Mọi sự kiện kiểm thử tới SIEM đúng actor/tenant/thời điểm; phát hiện mất log và can thiệp; truy vấn dữ liệu lưu giữ được.
T06	Chống mã độc và DLP	Mẫu thử an toàn tạo cảnh báo, xử lý/cách ly theo policy; không dùng malware thật ngoài phạm vi kiểm thử được duyệt.
T07	Lỗi thành phần HA	Mất controller, compute, storage node, FW/LB/ISP theo kịch bản; đo gián đoạn và không mất tính nhất quán.
T08	Bất biến và restore	Thử xóa/sửa bằng tài khoản cloud admin bị ngăn; khôi phục bản sạch trong môi trường cô lập, kiểm tra dữ liệu và ứng dụng.
T09	Mất toàn bộ DC	DR dùng được IAM/DNS/KMS và các dịch vụ ưu tiên; đạt RPO/RTO đã phê duyệt; không dual-writer; có failback.
T10	Khởi động nguội	Phục hồi được theo thứ tự phụ thuộc khi toàn bộ control plane dừng; bí mật và tài liệu khẩn cấp tiếp cận được.
T11	Chuỗi phát hành	Image sai chữ ký/digest hoặc không qua gate bị chặn; truy nguyên được release và rollback thành công.
T12	Đánh giá độc lập	Pentest trong/ngoài, thử quyền nội bộ, xử lý phát hiện và retest; báo cáo rõ mọi giới hạn phạm vi.

18 Rủi ro trọng yếu và trách nhiệm

Rủi ro mẫu	Biện pháp thiết kế và phép thử	Người chịu trách nhiệm
Cloud admin lạm quyền	Tách vai trò/khóa/log; PAM, phê duyệt nhiều bên, cảnh báo export; T03–T05.	CISO + trưởng vận hành
Truy cập chéo tenant	Cách ly API/network/storage, quota và policy; T02.	Platform + Network
Ransomware lan sang backup	Kho độc lập, quyền xóa riêng, bất biến, bản sao sạch; T08.	Backup + SOC
Mất DC hoặc kết nối liên site	Cụm DR độc lập, fencing, replica nhất quán, dung lượng dự phòng; T09.	Hạ tầng + chỉ huy DR
Lỗi bản dựng XOR hoặc dependency	SBOM, review, ký artifact, gate kiểm thử và rollback; T11.	DevSecOps
Mất khóa hoặc vòng phụ thuộc phục hồi	HSM/KMS HA, backup khóa, thủ tục khẩn cấp, cold start; T04/T10.	Quản trị khóa + GRC
Sự cố tương quan hai IDC	Xác minh điện/cáp/ISP; BIA và bản sao ngoài miền lỗi chung; kiểm tra nhà cung cấp.	Chủ quản + IDC/Network

Các rủi ro này là danh mục khởi tạo, chưa có điểm xác suất/tác động hoặc mức tồn dư được phê duyệt. HS03 phải đánh giá chi tiết theo dữ liệu thực tế, bao gồm tác động tới lợi ích công cộng, trật tự/an toàn xã hội hoặc an ninh quốc gia khi liên quan. [S1, Điều 22 khoản 5, tr.16]

Mô hình trách nhiệm chung

XOR chịu trách nhiệm hạ tầng, ảo hóa, control plane, dịch vụ quản trị và các dịch vụ được cam kết quản lý. Chủ quản khách hàng chịu trách nhiệm mục đích xử lý, phân loại dữ liệu, người dùng và ứng dụng; với IaaS, gồm hệ điều hành khách và cấu hình ứng dụng. Với dịch vụ quản lý, phần XOR vận hành phải được ghi cụ thể trong hợp đồng. Hai bên phối hợp log, ứng cứu, BIA, backup và kiểm tra.

Bộ phận GRC quản lý ma trận và hồ sơ; trưởng kỹ thuật xác nhận thiết kế thực tế; SOC xác nhận vận hành; đơn vị đánh giá cung cấp báo cáo; chủ quản quyết định chấp nhận rủi ro và thực hiện thủ tục phê duyệt. Trách nhiệm pháp lý của chủ quản không chuyển hết cho nhà cung cấp chỉ bằng SLA.

19 Lộ trình hoàn thiện và điều kiện đóng hồ sơ

Bước	Sản phẩm và điều kiện chuyển bước
1 Chốt phạm vi	Chủ quản, đơn vị vận hành, dịch vụ, loại dữ liệu, đối tượng phục vụ; chọn khoản Điều 14 có bằng chứng. Chốt giả định MH3/Mức 4 nếu dùng dự thảo.
2 Khảo sát thực tế	As-built DC/DR, phiên bản XOR và upstream, SBOM, asset/IP/rack, mạng, cấu hình bảo mật, hợp đồng IDC/ISP, tải và dung lượng.
3 Hoàn thiện thiết kế	LLD và luồng kết nối; BIA/RPO/RTO; chọn giải pháp còn thiếu dựa trên chức năng và tích hợp; dự toán theo số đo, không theo flavor mẫu.
4 Triển khai và vận hành	Áp baseline, phân quyền, log/SOC, backup/DR, quy trình và đào tạo. Thu thập bằng chứng thật, có thời gian và phiên bản.
5 Kiểm tra và khắc phục	Thực hiện T01–T12, checklist đến từng tiểu mục; đóng phát hiện bằng retest; xác định giới hạn và rủi ro tồn dư.
6 Thẩm định và phê duyệt	Hoàn thiện HS01–HS05, xin ý kiến chuyên môn, gửi thẩm định đúng thẩm quyền, trình chủ quản phê duyệt; bảo quản bộ hồ sơ đúng phiên bản.

Dữ liệu sizing cần thu thập

Số host và miền lỗi, tỷ lệ oversubscription, RAM/vCPU thực dùng, IOPS/throughput/p99 latency, EPS và kích thước log, dữ liệu thay đổi mỗi giờ, cửa sổ backup, tỷ lệ tăng trưởng, peak traffic và năng lực kiểm tra TLS/IPS/WAF. Dung lượng DR phải đủ tập dịch vụ cam kết phục hồi cùng headroom và tải vận hành bảo mật.

Công thức ước lượng log thô: EPS × byte/sự kiện × 86.400 × số ngày. Ví dụ giả định 5.000 EPS × 1.000 byte × 180 ngày ≈ 77,76 TB thập phân, chưa tính chỉ mục, replica, nén và dự phòng. Phải tính lại theo số tháng lưu thực tế và phép đo; ví dụ không phải cấu hình hiện có của XOR.

Điều kiện đóng bộ hồ sơ

• Phạm vi, căn cứ cấp độ và thiết kế thực tế được chốt; danh mục tài sản khớp kiến trúc và bằng chứng.

• Mỗi tiểu mục áp dụng có biện pháp, đầu mối, bằng chứng và kết quả; mọi mục không áp dụng có căn cứ. Không để “Chưa đủ bằng chứng” ở yêu cầu cần kết luận.

• Kiểm thử HA/DR/restore/cách ly và kiểm soát đặc quyền đạt tiêu chí đã phê duyệt; khắc phục và retest có xác nhận.

• Hồ sơ chuyên môn, thẩm định và quyết định được chủ thể có thẩm quyền ban hành. Việc ban hành quy trình và mua thiết bị chưa thay cho chứng minh thực thi.

20 Nguồn tham chiếu và lưu ý sử dụng

S1. Nghị định 331/2026/NĐ-CP ngày 19/8/2026 về bảo vệ an ninh mạng đối với hệ thống thông tin. Đã đối chiếu bản ký tại workspace, các trang 9, 11–17, 30–32; ngày hiệu lực được xác minh trên Cổng văn bản Chính phủ ngày 17/10/2026. Trang văn bản: https://vanban.chinhphu.vn/?docid=219243&pageid=27160

S2. TCVN 14423:2026, An ninh mạng – Hệ thống thông tin – Yêu cầu cơ bản. Đã kiểm tra SHA-256 của đúng bản nguồn nội bộ và đối chiếu ảnh Điều 6, trang 58–81; Phụ lục A.4, trang 109–111. Bìa/lời nói đầu là năm 2026; nguồn có một số chỗ hiển thị năm chưa nhất quán. Không đính kèm hoặc tái phát hành PDF có bản quyền.

SHA-256 S2: 76c6c11eadf8aec7f0b95940463ac715df50c6356e234492e54d6e9f78c8647c

S3. Dự thảo TCVN An ninh mạng – Nền tảng đám mây phục vụ hạ tầng số trọng yếu – Yêu cầu chung, 153 trang, chưa có số tiêu chuẩn chính thức. Đã kiểm tra SHA-256, tra Điều 4/5 và các bảng áp dụng liên quan. Có tham chiếu chéo chưa nhất quán, ví dụ Bảng 1/Bảng 2 và phụ lục vật lý; bản mẫu dùng nội dung điều khoản thực đọc, không tự sửa bản dự thảo hoặc coi đây là căn cứ pháp lý đã có hiệu lực.

SHA-256 S3: c5b5bbc83f860709be945f9ad7d2c01cba40188d066ff891e03fd3cf9f6849cf

S4. OpenStack Security Guide: https://docs.openstack.org/security-guide/ — nguồn tham khảo kiến trúc; có cảnh báo về thế hệ phát hành tài liệu. Phải đối chiếu bản OpenStack và phần tùy biến XOR thực tế trước khi dùng cấu hình.

S5. Ceph Stretch Clusters: https://docs.ceph.com/en/latest/rados/operations/stretch-mode/ — dùng để xem xét quorum và rủi ro stretch; trang latest là tài liệu phiên bản phát triển. Bản thiết kế không yêu cầu triển khai stretch và chưa chốt phiên bản Ceph.

S6. Kubernetes Security Checklist: https://kubernetes.io/docs/concepts/security/security-checklist/ — tham khảo hardening cho dịch vụ Kubernetes khi nằm trong danh mục cung cấp thực tế.

S7. Đầu vào người dùng ngày 17/10/2026: phạm vi toàn bộ nền tảng; XOR STACK CLOUD đóng gói từ OpenStack; IDC Cầu Giấy là DC và IDC Nam Thăng Long là DR. Hình kiến trúc gửi kèm và khảo sát cũ trong workspace chỉ giúp định hướng, không là kết quả kiểm tra hiện trạng.

Phân biệt hồ sơ thiết kế và hồ sơ đánh giá

Tệp này là tài liệu kiến trúc tham chiếu và khung hồ sơ để đội XOR triển khai công việc. Chưa có cấu hình truy xuất trực tiếp, kiểm thử hệ thống, báo cáo rủi ro hoàn chỉnh, ý kiến chuyên môn hoặc quyết định phê duyệt. Các trạng thái này được giữ rõ để bộ hồ sơ có thể hoàn thiện bằng bằng chứng thật.